Semana 01 — Ejemplo de trabajo del Grupo 2

Grupo 2 · rol Azul · ejemplo de trabajo

Prof. César Rodríguez | ELECTRONICA | 1 de noviembre de 2026

Curso	CYBERSEGURIDAD — Ciberseguridad Aplicada
Semana	01 de 10
Fase	1 — Fundamentos, criptografía y marco legal
Grupo	2
Rol	Azul
Entrega	GitHub, carpeta semana_01/
Corte	Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

1 Tu rol en la práctica

Parte de su propia captura cruda y aplica el control equivalente: configuración, parche o regla de red. Repite el ataque para demostrar que falla y documenta el antes y el después.

- Leer su propia evidencia cruda y elegir el control que corta el ataque en el punto más barato.
- Aplicar el control y repetir el ataque para demostrar que ya no funciona.
- Documentar el antes y el después con los mismos comandos y la diferencia medida.

2 Qué aporta este rol al entregable

La mitigación aplicada, el comando de verificación y la comparación de resultados.

3 Ejemplo paso a paso

El rol Azul parte de su propia captura cruda, elige el control más barato y repite la misma medición. El entregable es la comparación antes/después, no la captura suelta: un control sin verificación es una intención.

3.1 Fijar la línea base

Antes de tocar nada se mide lo que hay. Se repiten los mismos comandos que se usarán después, porque comparar mediciones distintas no demuestra nada.

```
docker compose up -d
docker compose ps
ss -tulpn | grep -E ':8081|:3000|:2222' | tee semana_01/evidencia/azul_antes_servicios.txt
curl -sI http://127.0.0.1:8081/ | grep -i '^server' | tee semana_01/evidencia/azul_antes_server.txt
```

3.2 Elegir el control por coste

Entre dos controles que cortan lo mismo, se aplica el que se verifica con un comando y no rompe el resto del laboratorio. Aquí: cerrar el acceso de root por SSH y dejar de anunciar la versión del servidor web.

3.3 Aplicar el control

Cada cambio se hace con un comando reproducible. Si el contenedor no tiene el archivo esperado, se documenta como control no aplicado en lugar de simularlo.

```
docker exec objetivo-linux sh -c "sed -i -E 's/^#?PermitRootLogin.*/PermitRootLogin no/' /etc/ssh/sshd_config && sshd -t && (kill -HUP 1 || true)"
docker exec objetivo-linux sshd -T | grep -E '^(permitrootlogin|maxauthtries)' | tee semana_01/evidencia/azul_control_ssh.txt
docker exec objetivo-web sh -c "printf '\nServerTokens Prod\nServerSignature Off\n' >> /etc/apache2/apache2.conf && apache2ctl -k graceful"
```

3.4 Repetir la medición y diferenciar

La misma orden del inicio, sobre el sistema ya cambiado, y un diff explícito. Si el resultado no cambia, el control no sirvió y eso también se reporta.

```
ss -tulpn | grep -E ':8081|:3000|:2222' > semana_01/evidencia/azul_despues_servicios.txt
curl -sI http://127.0.0.1:8081/ | grep -i '^server' > semana_01/evidencia/azul_despues_server.txt
diff semana_01/evidencia/azul_antes_server.txt semana_01/evidencia/azul_despues_server.txt | tee semana_01/evidencia/azul_diff.txt
```

3.5 Control aplicado y verificación

Control aplicado y verificación

Servicio	Puerto	Estado antes	Control aplicado	Verificación después
Linux del laboratorio	2222	Root con acceso por SSH	PermitRootLogin no y sshd -t antes de recargar	sshd -T muestra permitrootlogin no
DVWA	8081	Cabecera Server con versión de Apache	ServerTokens Prod y ServerSignature Off	La cabecera ya no anuncia versión
Juice Shop	3000	Cabecera Server con versión de Express	Sin control: el servicio no expone esa opción	Sin cambio; se documenta el motivo

La columna de verificación se llena con la salida real, no con la esperada; si no hay diferencia, se escribe "sin cambio" y se explica por qué.

4 Qué guardar en el repositorio

El informe incluye la tabla de control y verificación, el diff antes/después y una conclusión con el coste de cada control: cuántos comandos, cuánto riesgo de romper el servicio y qué queda expuesto después.

```
semana_01/
|-- informe.md
|-- evidencia/
|   |-- azul_antes_servicios.txt
|   |-- azul_despues_servicios.txt
|   |-- azul_antes_server.txt
|   |-- azul_despues_server.txt
|   |-- azul_control_ssh.txt
|   `-- azul_diff.txt
`-- README.md
```

- La medición de antes y la de después usan exactamente el mismo comando.
- Cada control tiene su comando de verificación y su salida real pegada.
- Si un control no se pudo aplicar, está dicho con el motivo, no omitido.
- El diff está en evidencia/ y el informe lo cita línea por línea.

5 Cómo se corrige

Criterio	Peso
Cobertura completa de puertos y servicios del objetivo	3,0
Evidencia reproducible de cada hallazgo	2,5
Uso correcto del vocabulario de amenazas	2,0
Priorización justificada por impacto y probabilidad	1,5
Redacción clara y evidencia anonimizada	1,0
Total	**10,0**

- No se cambian credenciales del laboratorio sin anotarlas en el README privado del grupo.
- Recargar un servicio cuenta como cambio de configuración; se documenta el comando exacto.

Recuerda

El trabajo es independiente: cada grupo usa su propio repositorio y su propio laboratorio, y la comparación de resultados es en clase. Corte: Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.